EUROPEAN UNION AGENCY
FOR CYBERSECURITY

INSTRUKCJA KONFIGURACJI

Aplikacja testowa z logowaniem Microsoft Entra ID – kurs „Cyberbezpieczeństwo w codziennej pracy”

PAŹDZIERNIK 2026

Opracowanie
DC9 Cyber sp. z o.o.

HISTORIA DOKUMENTU

// WERSJA ROBOCZA – USUŃ TĘ SEKCJĘ I STRONĘ PRZED PUBLIKACJĄ

Data	Wersja	Zmiana	Autor
2026-10-26	1.0	Pierwsza wersja instrukcji	DC9 Cyber sp. z o.o.

SPIS TREŚCI

1. OPIS ROZWIĄZANIA 6
1.1 JAK DZIAŁA APLIKACJA 6
1.2 ARCHITEKTURA 6
1.3 WYMAGANIA 6
2. PRZYGOTOWANIE 7
2.1 LISTA KONTROLNA 7
2.2 ADRESY, KTÓRE TRZEBA ZAREJESTROWAĆ 7
3. REJESTRACJA W ENTRA ID 8
3.1 REJESTRACJA 8
3.2 UWIERZYTELNIANIE I SEKRET 8
3.3 ROLA DOSTĘPU DO RAPORTU 8
3.4 OŚWIADCZENIA W TOKENIE 8
3.5 UPRAWNIENIA 8
3.6 PRZYPISANIE UŻYTKOWNIKÓW 8
3.7 WARTOŚCI DO KONFIGURACJI SERWERA 8
4. INSTALACJA NA SERWERZE 10
4.1 DOCKER 10
4.2 POBRANIE APLIKACJI 10
4.3 PLIK KONFIGURACJI 10
4.4 URUCHOMIENIE 10
4.5 HTTPS I PUBLICZNY ADRES 10
5. KONFIGURACJA APLIKACJI 12
5.1 ZMIENNE ŚRODOWISKOWE 12
5.2 ZAŚWIADCZENIE UCZESTNICTWA 12
5.3 BANK PYTAŃ 13
6. ODBIÓR 14
6.1 TEST DZIAŁANIA 14
6.2 KOMUNIKAT DO UCZESTNIKÓW 14
7. EKSPLOATACJA 15
7.1 KOPIA ZAPASOWA 15
7.2 AKTUALIZACJA 15
7.3 ODNOWIENIE SEKRETU ENTRA ID 15
7.4 USUWANIE DANYCH 15

7.5 DZIENNIKI 15

8. BEZPIECZEŃSTWO I DANE OSOBOWE 16

8.1 ZABEZPIECZENIA APLIKACJI 16

8.2 DANE OSOBOWE 16

8.3 OGRANICZENIA 16

9. ROZWIĄZYWANIE PROBLEMÓW 17

9.1 BŁĘDY MICROSOFT ENTRA ID 17

9.2 KOMUNIKATY APLIKACJI 17

A ZAŁĄCZNIK: WZÓR PLIKU .ENV 18

B ZAŁĄCZNIK: ADRESY APLIKACJI 19

PODSUMOWANIE

Instrukcja prowadzi administratora przez uruchomienie aplikacji testowej kursu „Cyberbezpieczeństwo w codziennej pracy" w organizacji: od rejestracji aplikacji w Microsoft Entra ID, przez instalację na serwerze z Dockerem i udostępnienie przez HTTPS, po odbiór, codzienną eksploatację i rozwiązywanie problemów.

Aplikacja pozwala pracownikom zalogować się kontem służbowym, rozwiązać diagnozę wstępną i test końcowy, a po zaliczeniu pobrać dwustronicowe zaświadczenie uczestnictwa w PDF. Osoby z rolą administratora widzą raport wyników i pobierają eksport CSV.

Tabela 1: Etapy wdrożenia

Etap	Kto	Czas
Rejestracja aplikacji w Entra ID (rozdział 3)	administrator Entra ID	ok. 20 min
Serwer, Docker i HTTPS (rozdział 4)	administrator serwera	ok. 30–45 min
Konfiguracja i bank pytań (rozdział 5)	administrator serwera	ok. 10 min
Odbiór (rozdział 6)	administrator i jeden uczestnik testowy	ok. 15 min

Kod aplikacji: https://github.com/dc9-enisa/cyber-awareness-test. Repozytorium zawiera wyłącznie pytania przykładowe; pełny bank pytań kursu dostarcza autor kursu (rozdział 5.3).

1. OPIS ROZWIĄZANIA

1.1 JAK DZIAŁA APLIKACJA

Uczestnik otwiera adres aplikacji i loguje się kontem Microsoft Entra ID organizacji. Rozwiązuje diagnozę wstępną (przed kursem) i test końcowy (po kursie), pytanie po pytaniu, z możliwością powrotu do oddania testu. Po oddaniu widzi wynik ogółem i w każdym module oraz omówienie każdej odpowiedzi z numerem slajdu do powtórki.

Treść odpowiedzi nie jest zapisywana – tylko wynik.

Po zaliczeniu testu końcowego (domyślnie co najmniej 20 z 25 pytań) uczestnik pobiera zaświadczenie uczestnictwa: strona 1 z imieniem i nazwiskiem, datą, wynikiem i numerem do weryfikacji, strona 2 z zakresem szkolenia. Wynik każdej oddanej próby trafia do pliku wyników na serwerze.

Administrator raportu (rola aplikacji w Entra ID) widzi liczbę uczestników i zaliczeń, odsetek poprawnych odpowiedzi w każdym module, listę uczestników z najlepszym wynikiem i numerem zaświadczenia oraz pobiera eksport CSV.

1.2 ARCHITEKTURA

Tabela 2: Elementy rozwiązania

Element	Rola
Przeglądarka uczestnika	dostęp przez HTTPS, ciasteczko sesji
Microsoft Entra ID	logowanie (OpenID Connect), przypisanie użytkowników i roli raportu
Serwer pośredniczący (Caddy, nginx, Traefik)	certyfikat TLS, publiczny adres, przekazanie ruchu do aplikacji
Kontener aplikacji	logika testu, zaświadczenia, raport; nasłuch na porcie 8080
Wolumen `/data`	plik wyników `wyniki.jsonl`

Aplikacja łączy się wychodząco wyłącznie z `login.microsoftonline.com` (metadane, klucze podpisu, wymiana kodu logowania). Nie korzysta z innych usług zewnętrznych, analityki ani zasobów z internetu.

1.3 WYMAGANIA

- serwer z systemem Linux (sprawdzono Ubuntu 24.04), 1–2 vCPU, 1–2 GB RAM, 10–20 GB dysku,
- Docker Engine z wtyczką Compose,
- nazwa domenowa (np. `szkolenie.twoja-organizacja.pl`) wskazująca na serwer pośredniczący,
- certyfikat TLS (Caddy uzyskuje go automatycznie z Let's Encrypt, jeśli porty 80 i 443 są dostępne z internetu),
- konto z uprawnieniami **Application Administrator** lub **Cloud Application Administrator** w Entra ID (rejestracja aplikacji, przypisanie użytkowników, zgoda administratora),
- połączenie wychodzące HTTPS z serwera do `login.microsoftonline.com`.

2. PRZYGOTOWANIE

2.1 LISTA KONTROLNA

Tabela 3: Dane potrzebne przed rozpoczęciem

Co	Przykład	Gotowe
Publiczny adres aplikacji	`https://szkolenie.twoja-organizacja.pl`	☐
Rekord DNS (A lub CNAME) na serwer pośredniczący	`szkolenie IN A 203.0.113.10`	☐
Serwer z Dockerem	Ubuntu 24.04, adres wewnętrzny	☐
Dostęp administratora Entra ID	rola Application Administrator	☐
Grupa uczestników w Entra ID	„Szkolenie cyberbezpieczeństwo – uczestnicy”	☐
Osoby z dostępem do raportu	np. dział bezpieczeństwa, HR	☐
Nazwa organizacji na zaświadczeniu	„Twoja Organizacja sp. z o.o.”	☐
Administrator danych i kontakt (RODO)	akapit do strony „Informacja o danych”	☐
Okres przechowywania wyników	365 dni	☐
Plik pełnego banku pytań	`questions.json` od autora kursu	☐

2.2 ADRESY, KTÓRE TRZEBA ZAREJESTROWAĆ

Z publicznego adresu aplikacji powstają dwa adresy wpisywane w Entra ID. Muszą zgadzać się co do znaku, łącznie z `https://` i brakiem ukośnika na końcu.

Tabela 4: Adresy powrotu

Adres	Przeznaczenie
`https://<adres>/auth/callback`	powrót po zalogowaniu (Redirect URI)
`https://<adres>/wylogowano`	powrót po wylogowaniu

3. REJESTRACJA W ENTRA ID

Kroki wykonuje się w Microsoft Entra admin center. Nazwy pozycji menu podano w wersji angielskiej, jak w konsoli.

3.1 REJESTRACJA

1. Przejdź do **Identity → Applications → App registrations → New registration**.
2. **Name:** `Cyberbezpieczeństwo – test`.
3. **Supported account types:** *Accounts in this organizational directory only (Single tenant)*.
4. **Redirect URI:** platforma **Web**, adres `https://<adres>/auth/callback`.
5. Kliknij **Register**.
6. Na karcie **Overview** zapisz **Application (client) ID** i **Directory (tenant) ID**.

3.2 UWIERZYTELNIANIE I SEKRET

1. **Authentication → Web → Add URI:** dodaj `https://<adres>/wylogowano`.
2. W tej samej karcie pozostaw **wyłączone** *Access tokens* i *ID tokens* w sekcji *Implicit grant and hybrid flows*. Aplikacja używa przepływu kodu autoryzacji z PKCE.
3. **Certificates & secrets → Client secrets → New client secret.** Opis: `serwer aplikacji`, ważność: 12 lub 24 miesiące.
4. Skopiuj kolumnę **Value** (nie *Secret ID*). Wartość jest widoczna tylko raz.
5. Zapisz datę wygaśnięcia sekretu w kalendarzu zespołu (rozdział 7.3).

Aplikacja jest jednodostępna: wpuszcza wyłącznie konta Twojej dzierżawy.

3.3 ROLA DOSTĘPU DO RAPORTU

1. **App roles → Create app role.**
2. **Display name:** `Raport wyników`; **Allowed member types:** *Users/Groups*; **Value:** `Raporty`; **Description:** *Dostęp do raportu wyników i eksportu CSV*.
3. Zaznacz **Do you want to enable this app role?** i zapisz.
4. Utwórz drugą rolę dla uczestników: **Display name:** `Uczestnik`; **Allowed member types:** *Users/Groups*; **Value:** `Uczestnik`; **Description:** *Rozwiązywanie testu i pobieranie własnego zaświadczenia*.

Wartość `Raporty` musi być równa zmiennej `ADMIN_ROLE` (domyślnie `Raporty`). Rola `Uczestnik` nie daje uprawnień w aplikacji – służy tylko do przypisania osób, bo gdy aplikacja ma własne role, Entra ID nie pozwala przypisać użytkownika z dostępem domyślnym (*Default Access*).

3.4 OŚWIADCZENIA W TOKENIE

Token configuration → Add optional claim → ID → email. Krok jest opcjonalny: aplikacja bierze login z `preferred_username`, a `email` służy jako zapas.

3.5 UPRAWNIENIA

API permissions: wystarczą domyślne uprawnienia delegowane Microsoft Graph `openid`, `profile`, `email` (oraz `User.Read`, dodawane automatycznie). Jeśli polityka organizacji wymaga zgody administratora, kliknij **Grant admin consent for** .

3.6 PRZYPISANIE UŻYTKOWNIKÓW

1. **Identity → Applications → Enterprise applications** → wyszukaj `Cyberbezpieczeństwo – test`.
2. **Properties → Assignment required? = Yes → Save**.
3. **Users and groups → Add user/group:**
   - grupa uczestników z rolą **Uczestnik**,
   - osoby lub grupa z dostępem do raportu z rolą **Raport wyników**.

WAŻNE

Bez „Assignment required = Yes" do aplikacji może się zalogować każdy użytkownik dzierżawy.

Osoba z rolą *Raport wyników* może też rozwiązywać test jak każdy uczestnik.

3.7 WARTOŚCI DO KONFIGURACJI SERWERA

Tabela 5: Przekazanie wartości administratorowi serwera

Wartość z Entra ID	Zmienna
Directory (tenant) ID	`ENTRA_TENANT_ID`
Application (client) ID	`ENTRA_CLIENT_ID`
Client secret – Value	`ENTRA_CLIENT_SECRET`
Value roli aplikacji	`ADMIN_ROLE`

Sekret przekaż kanałem szyfrowanym (menedżer haseł, zaszyfrowana wiadomość). Nie wysyłaj go zwykłym e-mailem ani komunikatorem.

4. INSTALACJA NA SERWERZE

4.1 DOCKER

Na Ubuntu 24.04 (jako użytkownik z `sudo`):

```
sudo apt-get update
sudo apt-get install -y ca-certificates curl git
sudo install -m 0755 -d /etc/apt/keyrings
sudo curl -fsSL https://download.docker.com/linux/ubuntu/gpg \
  -o /etc/apt/keyrings/docker.asc
echo "deb [arch=$(dpkg --print-architecture) \
  signed-by=/etc/apt/keyrings/docker.asc] \
  https://download.docker.com/linux/ubuntu \
  $(. /etc/os-release && echo $VERSION_CODENAME) stable" \
  | sudo tee /etc/apt/sources.list.d/docker.list
sudo apt-get update
sudo apt-get install -y docker-ce docker-ce-cli containerd.io \
  docker-compose-plugin
```

4.2 POBRANIE APLIKACJI

```
sudo mkdir -p /opt/cyber-awareness-test
sudo chown $USER /opt/cyber-awareness-test
git clone https://github.com/dc9-enisa/cyber-awareness-test.git \
  /opt/cyber-awareness-test
cd /opt/cyber-awareness-test
```

4.3 PLIK KONFIGURACJI

```
cp .env.przyklad .env
chmod 600 .env
openssl rand -base64 32     # wynik wpisz jako SESSION_KEY
nano .env
```

Uzupełnij co najmniej `BASE_URL`, trzy zmienne `ENTRA_…`, `SESSION_KEY`, `ORG_NAME` i `PRIVACY_TEXT`. Opis wszystkich zmiennych: rozdział 5.1, pełny wzór pliku: załącznik A.

4.4 URUCHOMIENIE

```
docker compose up -d --build
docker compose ps            # stan: healthy
docker compose logs --tail 20
```

Podczas budowy obrazu wykonują się testy automatyczne aplikacji; błąd testu przerywa budowę. W dzienniku powinna pojawić się linia `wersja pytań …, nasłuch :8080, adres https://…`. Błąd konfiguracji (np. brak sekretu, adres `http` poza localhost) zatrzymuje kontener z czytelnym komunikatem.

Kontener działa bez uprawnień administratora (użytkownik 65532), z systemem plików tylko do odczytu, bez dodatkowych uprawnień jądra. Zapis jest możliwy wyłącznie w wolumenie `/data`.

4.5 HTTPS I PUBLICZNY ADRES

Domyślny `docker-compose.yml` wystawia aplikację tylko na `127.0.0.1:8080`. Publiczny adres zapewnia serwer pośredniczący z certyfikatem TLS.

Aplikacja nie obsługuje TLS sama – zawsze stawiaj ją za serwerem pośredniczącym.

Wariant A – Caddy na tym samym serwerze (porty 80 i 443 dostępne z internetu; certyfikat Let's Encrypt automatycznie):

```
sudo apt-get install -y caddy
sudo tee /etc/caddy/Caddyfile >/dev/null <<'EOF'
szkolenie.twoja-organizacja.pl {
    encode gzip
    reverse_proxy 127.0.0.1:8080
}
EOF
sudo systemctl reload caddy
```

Wariant B – istniejący serwer pośredniczący w organizacji. W `docker-compose.yml` zmień `127.0.0.1:8080:8080` na `<adres-wewnętrzny>:8080:8080` i ogranicz dostęp do portu zaporą do adresu serwera pośredniczącego. Przykład dla Caddy:

```
szkolenie.twoja-organizacja.pl {
    reverse_proxy 10.0.0.20:8080
}
```

Przykład dla nginx (fragment `server` z `listen 443 ssl`):

```
location / {
    proxy_pass http://10.0.0.20:8080;
    proxy_set_header Host $host;
    proxy_set_header X-Forwarded-Proto https;
}
```

Serwer pośredniczący musi przekazywać oryginalny nagłówek `Host` i nie może zmieniać nagłówka `Origin` – aplikacja odrzuca formularze z obcego źródła.

5. KONFIGURACJA APLIKACJI

5.1 ZMIENNE ŚRODOWISKOWE

Tabela 6: Zmienne środowiskowe

Zmienna	Wymagana	Opis
`BASE_URL`	tak	publiczny adres `https://…`, bez ukośnika na końcu
`ENTRA_TENANT_ID`	tak	Directory (tenant) ID
`ENTRA_CLIENT_ID`	tak	Application (client) ID
`ENTRA_CLIENT_SECRET`	tak	wartość sekretu klienta
`SESSION_KEY`	tak	min. 32 bajty, `openssl rand -base64 32`; zmiana wylogowuje wszystkich
`ORG_NAME`	tak	nazwa organizacji na zaświadczeniu
`PRIVACY_TEXT`	zalecana	administrator danych i kontakt na stronie `/prywatnosc`
`ADMIN_ROLE`	nie	wartość roli raportu (domyślnie `Raporty`)
`ADMIN_UPNS`	nie	loginy z dostępem do raportu bez roli, po przecinku
`RETENTION_DAYS`	nie	dni przechowywania wyników (domyślnie 365; `0` – bez usuwania)
`CERT_REQUIRE_PASS`	nie	`1` – zaświadczenie po zaliczeniu (domyślnie); `0` – po każdym teście końcowym
`CLIENT_IP_HEADER`	za proxy	nagłówek z adresem klienta, np. `CF-Connecting-IP`; tylko gdy port aplikacji jest dostępny wyłącznie dla serwera pośredniczącego
`QUESTIONS_FILE`	nie	ścieżka do pliku banku pytań w kontenerze
`DEV_LOGIN`	nie	`1` – logowanie testowe bez Entra, tylko na localhost; **nie w produkcji**

5.2 ZAŚWIADCZENIE UCZESTNICTWA

Zaświadczenie ma dwie strony A4 w poziomie. Strona 1: nazwa organizacji (`ORG_NAME`), imię i nazwisko z konta Entra ID, data ukończenia, wynik i próg, numer zaświadczenia (`XXXX-XXXX-XXXX-XXXX`) oraz adres weryfikacji. Strona 2: zakres szkolenia – 11 modułów z zagadnieniami. W stopce obu stron są znaki ENISA i „Finansowane przez Unię Europejską” oraz informacja o wydawcy.

Zaświadczenie potwierdza udział w szkoleniu i wynik testu. Nie jest certyfikatem ani kwalifikacją zawodową. Zasady identyfikacji ENISA nie pozwalają, by znak agencji sugerował certyfikację lub poparcie, dlatego treść zaświadczenia tego nie zmienia.

Numer można sprawdzić pod adresem `https://<adres>/weryfikacja` po zalogowaniu kontem organizacji.

ZNAK ENISA

Zaświadczenie wydaje organizacja. Stwierdza, że nie zostało wydane ani poświadczone przez ENISA ani UE.

5.3 BANK PYTAŃ

Obraz zawiera pytania przykładowe (3 + 5, oznaczone „PRZYKŁAD”). Pełny bank kursu (diagnoza 11, test końcowy 25, próg 20) dostarcza autor kursu jako plik `questions.json`.

1. Utwórz katalog `pytania` obok `docker-compose.yml` i skopiuj do niego `questions.json`.
2. W `docker-compose.yml` w sekcji `volumes` usługi `test` dodaj linię – `./pytania/questions.json:/pytania/questions.json:ro`.
3. W `.env` ustaw `QUESTIONS_FILE=/pytania/questions.json`.
4. `docker compose up -d` i sprawdź w dzienniku `wersja pytań 1.3…` (zamiast `demo`).

Pełnego banku pytań nie umieszczaj w publicznym repozytorium.

Aplikacja sprawdza format pliku przy starcie (4 odpowiedzi i 4 uzasadnienia, klucz A–D, znane moduły). Zmiana pytań nie wpływa na zapisane wyniki ani wydane zaświadczenia.

6. ODBIÓR

6.1 TEST DZIAŁANIA

Tabela 7: Lista odbiorcza

Krok	Oczekiwany wynik	OK
Otwórz `https://<adres>/healthz`	ok	☐
Otwórz `https://<adres>/`	strona powitalna, ważny certyfikat TLS	☐
Zaloguj się kontem uczestnika testowego	strona startowa z imieniem i nazwiskiem	☐
Zaloguj się kontem spoza przypisanej grupy	odmowa w Entra ID (AADSTS50105)	☐
Rozwiąż diagnozę wstępną	wynik i omówienie	☐
Rozwiąż test końcowy poniżej progu	wynik bez zaświadczenia, informacja o progu	☐
Rozwiąż test końcowy powyżej progu	przycisk zaświadczenia, PDF z 2 stronami	☐
Sprawdź numer w `/weryfikacja`	„Zaświadczenie jest prawdziwe”	☐
Otwórz `/admin` kontem uczestnika	„Brak dostępu”	☐
Otwórz `/admin` kontem z rolą Raport wyników	raport z wynikami uczestnika testowego	☐
Pobierz eksport CSV i otwórz w Excelu	polskie znaki, kolumny rozdzielone	☐
Wyloguj się	powrót na stronę „Wylogowano”	☐

Po odbiorze usuń wyniki uczestnika testowego (rozdział 7.4), aby nie trafiły do raportu.

6.2 KOMUNIKAT DO UCZESTNIKÓW

Przykładowa treść ogłoszenia:

> Zapraszamy do diagnozy wstępnej i testu końcowego szkolenia „Cyberbezpieczeństwo w codziennej pracy”: https://szkolenie.twoja-organizacja.pl. Zaloguj się kontem służbowym. Po zaliczeniu testu końcowego pobierzesz zaświadczenie uczestnictwa.

7. EKSPLOATACJA

7.1 KOPIA ZAPASOWA

Jedynym plikiem z danymi jest `wyniki.jsonl` w wolumenie `/data`. Kopia na żywo jest bezpieczna (plik jest tylko dopisywany):

```
docker compose cp test:/data/wyniki.jsonl \
  ./kopia/wyniki_$(date +%F).jsonl
```

Kopie przechowuj z tymi samymi ograniczeniami dostępu i okresem przechowywania co oryginał.

7.2 AKTUALIZACJA

```
cd /opt/cyber-awareness-test
git pull
docker compose up -d --build
```

Restart przerywa próby w toku (uczestnik rozpoczyna test od nowa); oddane wyniki i zaświadczenia pozostają. Aktualizację wykonuj poza godzinami szkoleń.

7.3 ODNOWIENIE SEKRETU ENTRA ID

Przed datą wygaśnięcia: utwórz nowy sekret (rozdział 3.2), wpisz go do `ENTRA_CLIENT_SECRET` w `.env`, wykonaj `docker compose up -d`, sprawdź logowanie, usuń stary sekret w Entra ID. Wygasły sekret powoduje błąd AADSTS7000222 przy każdym logowaniu.

7.4 USUWANIE DANYCH

Wyniki starsze niż `RETENTION_DAYS` są usuwane automatycznie (sprawdzenie co 6 godzin). Usunięcie danych jednej osoby (np. na wniosek):

```
docker compose stop test
docker run --rm -v cyber-awareness-test_wyniki:/data alpine \
  sh -c "grep -v '\"oid\":\"<oid>\"' /data/wyniki.jsonl \
  > /data/w.tmp && mv /data/w.tmp /data/wyniki.jsonl \
  && chown 65532:65532 /data/wyniki.jsonl"
docker compose start test
```

Identyfikator `oid` osoby znajdziesz w Entra ID (**Users** → → **Object ID**). Nazwa wolumenu: `docker volume ls`.

7.5 DZIENNIKI

`docker compose logs test` – start, błędy konfiguracji, nieudane logowania (z kodem błędu Entra ID), retencja. Dziennik nie zawiera odpowiedzi uczestników ani tokenów.

8. BEZPIECZEŃSTWO I DANE OSOBOWE

8.1 ZABEZPIECZENIA APLIKACJI

- logowanie OpenID Connect, przepływ kodu z PKCE (S256), klient poufny, weryfikacja podpisu tokenu (RS256, klucze Entra ID z obsługą rotacji), wystawcy, odbiorcy, dzierżawy, ważności, `nonce` i `state`,
- sesja w podpisanym (HMAC-SHA256) ciasteczku `HttpOnly`, `Secure`, `SameSite=Lax`, ważna 8 godzin,
- token CSRF w każdym formularzu i sprawdzenie nagłówka `Origin`; ciasteczka z prefiksem `__Host-`; wylogowanie unieważnia sesję,
- nagłówki zgodne z OWASP Secure Headers: Content-Security-Policy `default-src 'none'` bez `unsafe-inline`, `X-Frame-Options: DENY`, HSTS, `Permissions-Policy`, `Cross-Origin-Opener/Resource/Embedder-Policy`, `Referrer-Policy`, `Cache-Control: no-store`,
- limity: logowanie 20 żądań/min, ogółem 600/min na adres IP, formularz 64 KB, nagłówki 16 KB; brak listingu katalogów,
- dziennik zdarzeń bezpieczeństwa (JSON): logowania, odmowy dostępu, raport, eksport CSV, błędy CSRF, przekroczenia limitów,
- połączenia wychodzące tylko do hosta Entra ID (ochrona przed SSRF),
- izolacja: uczestnik widzi tylko swoje próby, wyniki i zaświadczenia; raport tylko z rolą,
- obraz bez powłoki i menedżera pakietów, bez zależności zewnętrznych poza biblioteką standardową Go.

8.2 DANE OSOBOWE

Dla każdej oddanej próby zapisywane są: identyfikator konta Entra ID (`oid`), imię i nazwisko, login, część testu, data, liczba punktów ogółem i w modułach, zaliczenie, moduły z błędem w pytaniu KLUCZOWYM, numer zaświadczenia. Treść odpowiedzi nie jest zapisywana.

ADMINISTRATOR DANYCH

Administratorem danych jest organizacja wdrażająca aplikację.

Przed uruchomieniem organizacja powinna:

- określić podstawę prawną przetwarzania i uzupełnić `PRIVACY_TEXT` (administrator, kontakt, inspektor ochrony danych),
- ustalić okres przechowywania (`RETENTION_DAYS`) i krąg osób z rolą Raport wyników,
- objąć wolumen `/data` i kopie zapasowe kontrolą dostępu,
- ocenić potrzebę oceny skutków dla ochrony danych (DPIA) – zależnie od skali i sposobu wykorzystania wyników.

Strona `/prywatnosc` informuje uczestników o zakresie danych, dostępie, okresie przechowywania i ciasteczkach.

8.3 OGRANICZENIA

- jedna instancja: wyniki w pliku, próby w toku w pamięci serwera; przy wielu replikach potrzebna byłaby baza danych,
- sesji nie można unieważnić przed upływem 8 godzin inaczej niż zmianą `SESSION_KEY` (wylogowuje wszystkich); odebranie dostępu w Entra ID działa przy następnym logowaniu,
- raport nie dzieli wyników według działów.

9. ROZWIĄZYWANIE PROBLEMÓW

9.1 BŁĘDY MICROSOFT ENTRA ID

Tabela 8: Kody błędów Entra ID

Kod	Przyczyna	Rozwiązanie
AADSTS50011	adres powrotu nie zgadza się z zarejestrowanym	porównaj `BASE_URL` + `/auth/callback` z Redirect URI (https, brak ukośnika na końcu)
AADSTS50105	użytkownik nie jest przypisany do aplikacji	dodaj osobę lub grupę w Enterprise applications → Users and groups
AADSTS700016	aplikacji nie ma w tej dzierżawie	sprawdź `ENTRA_CLIENT_ID` i `ENTRA_TENANT_ID`
AADSTS7000215	nieprawidłowy sekret	wpisz *Value*, nie *Secret ID*
AADSTS7000222	sekret wygasł	rozdział 7.3
AADSTS65001	brak zgody na uprawnienia	Grant admin consent (rozdział 3.5)

9.2 KOMUNIKATY APLIKACJI

Tabela 9: Komunikaty aplikacji

Komunikat lub objaw	Przyczyna	Rozwiązanie
Kontener nie startuje: `konfiguracja: …`	brak lub błąd zmiennej	popraw `.env` zgodnie z komunikatem
`discovery Entra: …` w dzienniku	brak połączenia z `login.microsoftonline.com` lub zły tenant	sprawdź DNS, zaporę wychodzącą, `ENTRA_TENANT_ID`
„Sesja logowania wygasła”	logowanie trwało ponad 10 minut lub przeglądarka blokuje ciasteczka	zaloguj się ponownie; sprawdź, czy adres w przeglądarce = `BASE_URL`
„Niedozwolone źródło żądania”	serwer pośredniczący zmienia nagłówki lub adres ≠ `BASE_URL`	przekazuj `Host` bez zmian, otwieraj aplikację pod `BASE_URL`
„Brak dostępu” do raportu	brak roli Raport wyników	przypisz rolę i zaloguj się ponownie
„Ta próba jest już niedostępna”	restart serwera lub próba starsza niż 12 godzin	rozpocznij test od nowa
`QUESTIONS_FILE: …` / `pytania: …`	brak pliku lub błąd formatu banku pytań	sprawdź montowanie wolumenu i komunikat o pytaniu

A ZAŁĄCZNIK: WZÓR PLIKU .ENV

```
BASE_URL=https://szkolenie.twoja-organizacja.pl
ENTRA_TENANT_ID=00000000-0000-0000-0000-000000000000
ENTRA_CLIENT_ID=00000000-0000-0000-0000-000000000000
ENTRA_CLIENT_SECRET=<wartość sekretu>
SESSION_KEY=<wynik: openssl rand -base64 32>
ORG_NAME=Twoja Organizacja sp. z o.o.
PRIVACY_TEXT=Administratorem danych jest … Kontakt: …
ADMIN_ROLE=Raporty
ADMIN_UPNS=
RETENTION_DAYS=365
CERT_REQUIRE_PASS=1
CLIENT_IP_HEADER=CF-Connecting-IP
QUESTIONS_FILE=/pytania/questions.json
```

B ZAŁĄCZNIK: ADRESY APLIKACJI

Tabela 10: Adresy aplikacji

Adres	Dostęp	Opis
`/`	wszyscy	strona powitalna lub startowa uczestnika
`/auth/login`, `/auth/callback`	wszyscy	logowanie Entra ID
`/prywatnosc`	wszyscy	informacja o przetwarzaniu danych
`/healthz`	wszyscy	stan aplikacji (`ok`)
`/proba/…`	uczestnik	rozwiązywanie testu i wynik
`/zaswiadczenie/<numer>.pdf`	właściciel, administrator	zaświadczenie PDF
`/weryfikacja`	zalogowani	sprawdzenie numeru zaświadczenia
`/admin`	rola Raport wyników	raport wyników
`/admin/wyniki.csv`	rola Raport wyników	eksport CSV

O ENISA

Agencja Unii Europejskiej ds. Cyberbezpieczeństwa (ENISA) jest centrum eksperckim w dziedzinie bezpieczeństwa sieci i informacji dla UE, państw członkowskich, sektora prywatnego i obywateli Europy. ENISA współpracuje z tymi grupami, opracowując porady i rekomendacje dobrych praktyk w zakresie bezpieczeństwa informacji, wspiera państwa członkowskie we wdrażaniu prawa UE oraz działa na rzecz zwiększenia odporności europejskiej infrastruktury krytycznej i sieci. Więcej informacji: www.enisa.europa.eu.

ENISA
European Union Agency for Cybersecurity

Athens Office
Agamemnonos 14
Chalandri 15231, Attiki, Greece

Heraklion Office
95 Nikolaou Plastira
700 13 Vassilika Vouton, Heraklion, Greece

Brussels Office
Rue de la Loi 107
1049 Brussels, Belgium

enisa.europa.eu